

ADR 0017 — No arbitrary argv from the browser, held closed by a tripwire

- **Status:** Accepted
- **Date:** 2026-07-24
- **Milestone / issue:** M1.06c — Close the arbitrary-argv escape hatch from the browser (#144, child of #59)
- **Supersedes / superseded by:** — (builds on ADR 0016's single-executor seam; staleness/expiry enforcement is #145)

Context

The security model's Command Execution rules require direct argv execution, no shell, and argv built only from typed planners and validated domain values. After #143 the mutating argv had one construction site (planner's executor), but nothing proved the API boundary tight: a future route taking a raw command string, a DTO growing a freeform `args: Vec<String>` field, or a second spawn site slipping in would all compile silently.

An audit for #144 found no such hole today: every write body deserializes into a closed `#[serde(deny_unknown_fields)]` DTO or the typed `UndoAction` enum; five write routes accept no body at all; and the clone URL — the one client string that ever becomes a git argument — passes `validate_clone_url` and travels as its own argv entry.

Decision

Pin the audited posture with tests that fail when it regresses, in `git-vista-server::argv_boundary` (`#[cfg(test)]`):

1. **Spawn-site tripwire.** A source scan over `git-vista-server` and `git-vista-git` asserts every `Command::new` site lives in a short, commented allowlist and names `git` literally — no shells, no dynamic program names. A new spawn site fails the suite until a reviewer deliberately allowlists it.
2. **Serde adversarial fixtures.** Every write DTO refuses unknown fields (no smuggled `"args": [...]`), non-object shapes (no raw argv arrays), and the closed `UndoAction` enum refuses unknown variants. Option-shaped and empty ref names die in the typed `BranchName` gate.
3. **Wire adversarial fixtures.** The same payloads sent through the real session/CSRF middleware and real extractors — plus hostile clone URLs (`file://`, `ssh`, `ext::`, option-shaped, second-token smuggling) — are rejected at the API boundary with a client error, provably before any handler logic runs (stub handlers plant a marker the response must not contain).

Alternatives considered

- **Trust the type system alone.** The DTOs are already closed types, but nothing stops a future route from taking `Json<Vec<String>>`. Rejected: the tripwire makes that a red test, not a review hope.
- **A proc-macro/lint enforcing spawn sites.** Heavier machinery for the same guarantee; a source-scan test is dependency-free and readable.
- **Runtime argv auditing (log every spawn).** Detects after the fact; the point is refusing before git ever runs.

Consequences

- Adding a legitimate spawn site now requires touching the allowlist in the same PR — a deliberate, reviewable act.
- The wire fixtures document the exact hostile shapes considered; new attack shapes belong in `argv_boundary.rs` beside them.
- The security model's Command Execution section is annotated as enforced by this ADR; #145 builds staleness/expiry enforcement on the same seam.